

Smart Contract Re-audit Report

MoonsaleLiquidityToken

BNB Smart Chain · Solidity ^0.8.20

ENGAGEMENT METADATA

REPORT ID	ICG-2026-MSL-005 (Re-audit R2 of MSL-001)
CLIENT	Moonsale App
SCOPE	MoonsaleLiquidityToken.sol (R2 revision)
COMMIT / VERSION	Single source file, 380 SLOC, second-round remediation revision
METHODOLOGY	Manual re-audit, remediation verification
ISSUE DATE	April 23, 2026

Executive Summary

This report is the second re-audit of MoonsaleLiquidityToken, following the client's remediation of the findings raised in ICOGemHunters re-audit ICG-2026-MSL-003 (R1, April 23, 2026). The revised source is 380 SLOC, up from 360 in R1 and 252 in the original MSL-001 review. The added code concentrates on: a refactored `_addLiquidity` helper that tracks router refunds, a new `maxSwapThreshold` immutable replacing live `totalSupply()` reads, and an auto-delivery path in `confirmMarketingWallet` that settles stuck pending ETH at the moment a new marketing wallet is confirmed.

Of the 5 findings raised in R1: 3 are now fully Fixed (L-R1, L-R2, I-R1), and 2 are formally Acknowledged as accepted design choices (M-R1 bounded-MEV slippage model, I-R2 deployment-time compiler target). No new findings were identified in this round. The re-audit therefore produced 0 Critical, 0 High, 0 Medium, 0 Low, and 0 Informational new findings, with 2 carryover Acknowledged items.

The fixes were verified end-to-end. The `_addLiquidity` helper's refund math is correct: `refund = balance_post - (balPre - ethForLiq)` evaluates to `ethForLiq - actualETHConsumed`, which is the exact amount the router refunds. The `confirmMarketingWallet` auto-delivery path observes checks-effects-interactions: `pendingMarketingETH = 0` precedes the external call, and on send failure the value is restored without reverting the rotation itself. The `maxSwapThreshold` immutable is set once at construction and cannot drift.

The security score rises from 87/100 at R1 to 94/100 at R2, a cumulative improvement of 36 points from the original 58/100 assessment. The 6-point residual deduction reflects the Acknowledged bounded-MEV trade-off (M-R1, 4 points) and the compiler-target deployment concern (I-R2, 2 points). No findings block deployment. The contract is production-ready under the documented bounded-MEV design choice.

Score Progression

	Original (MSL-001)	R1 (MSL-003)	R2 (MSL-005)
Critical	0	0	0
High	3	0	0
Medium	5	1	0 new · 1 ack
Low	4	2	0
Info	4	2	0 new · 1 ack
Total new findings	16	5	0
Security Score	58 / 100	87 / 100	94 / 100

Remediation Status (R1 Findings)

The 5 findings raised in re-audit R1 (ICG-2026-MSL-003) were each verified against the R2 source. The table below lists each R1 finding with its current status and a verification note referencing the implementing line or design decision.

ID	Sev	Title	Status	Verification Note
M-R1	Medium	Same-block getAmountsOut leaves bounded sandwich extraction	Acknowledged	Design choice: getAmountsOut + maxSlippageBps pattern retained. Bounded MEV (1-5% per threshold crossing) accepted as industry-standard for fee-on-transfer auto-liquify tokens. No TWAP or oracle feed integration.
L-R1	Low	claimPendingMarketing griefable by reverting marketing wallet	Fixed	confirmMarketingWallet now auto-delivers pending ETH to the newly confirmed wallet in the same transaction (lines 303-313). nonReentrant added to the function. Pattern matches Option B of the R1 recommendation.
L-R2	Low	setSwapThreshold re-reads totalSupply() on every call	Fixed	New maxSwapThreshold immutable declared at line 60, set to supply / 100 in constructor (line 141). setSwapThreshold at line 320 uses minLimitAmount / 100 and maxSwapThreshold. No live totalSupply() reads.
I-R1	Info	addLiquidityETH refund not tracked in pendingLiqETH	Fixed	_addLiquidity refactored into a private helper (lines 236-251) with balPre snapshot. On success, refund = balance_post - (balPre - ethForLiq) is added to pendingLiqETH, preventing rescueETH from sweeping router refunds as unaccounted dust.
I-R2	Info	Compiler EVM target for BSC	Acknowledged	Deployment-time note, unchanged. Confirm Shanghai support on target nodes before deploying.

Scope & Methodology

In-Scope Files

File	Role	Reviewed
MoonsaleLiquidityToken.sol	ERC-20 with auto-liquidity and marketing fee; second-round remediation revision after MSL-003	Yes

R2 Methodology

- Diff between MSL-003 source (360 lines) and R2 source (380 lines), with the 5 R1 findings used as an explicit verification checklist.
- Walked the new _addLiquidity and _sendMarketing private helpers to confirm the refactor preserved the original logic and added only the intended refund tracking.
- Verified the refund arithmetic: confirmed that `refund = address(this).balance - (balPre - ethForLiq)` reduces to the router's actual refund amount, and confirmed that no unrelated ETH inflow can contaminate the calculation within a single transaction.
- Traced the new confirmMarketingWallet auto-delivery path for reentrancy and state-consistency: `pendingMarketingETH = 0` precedes the external call, the function is `nonReentrant`, and state is restored on send failure.

- Verified the `maxSwapThreshold` immutable replaces the previous runtime `totalSupply()` reads in `setSwapThreshold` with no semantic drift.
- Fresh pass over the remaining unchanged surface (constructor, `_update`, `_swapAndLiquify` body, owner controls) to detect any knock-on effects from the refactor.

Severity Classification

Severity	Definition
Critical	Direct loss of user or protocol funds, or unilateral takeover.
High	Realistic exploit with significant impact.
Medium	Conditional impact or material UX or availability concern.
Low	Limited impact; defence in depth.
Informational	Code quality, gas, documentation.

New Findings

No new findings were identified in this round. The R2 revision touches three areas (`_addLiquidity` refactor, `confirmMarketingWallet` auto-delivery, `maxSwapThreshold` immutable); each change was verified to be correct, to preserve the prior safety properties, and to introduce no new attack surface.

Carryover Acknowledged Items

Two R1 items remain Acknowledged rather than Fixed. They are not vulnerabilities in the traditional sense; they represent explicit design or deployment-time decisions.

- M-R1 Bounded-MEV slippage model. The `getAmountsOut` reference combined with `maxSlippageBps` (bounded 100-500) caps sandwich extraction at 1-5% per threshold crossing. The client has chosen not to integrate a TWAP or oracle feed. This is industry-standard for fee-on-transfer auto-liquify tokens and is an accepted operational trade-off. Recommendation if MEV resistance is later required: keep `maxSlippageBps` at the low end of the allowed range (100-200) to tighten the extractable bound.
- I-R2 Compiler EVM target. `pragma solidity ^0.8.20` with default settings emits PUSH0. BSC mainnet supports Shanghai; deployments to forked, archive, or lagging nodes require explicit settings: `{ evmVersion: "paris" }` in the build configuration. This is addressed at the build-pipeline level, not in the contract source.

Positive Observations

- Round-2 remediation mirrors the R1 recommendations precisely: L-R1 implements Option B (auto-delivery on rotation), L-R2 adds the suggested `maxSwapThreshold` immutable, I-R1 adds the suggested `balPre` snapshot. The fidelity to the prior recommendations is notable.
- The refund-tracking arithmetic in `_addLiquidity` is provably correct: $\text{balance_post} = \text{balPre} - \text{ethForLiq} + \text{refund}$, so the expression $\text{balance_post} - (\text{balPre} - \text{ethForLiq})$ reduces to `refund` without underflow risk (refund is always non-negative for canonical router implementations).
- Extracting `_addLiquidity` and `_sendMarketing` into dedicated private helpers simplifies `_swapAndLiquify` and makes each ETH-handling path easier to audit in isolation.
- The `nonReentrant` modifier added to `confirmMarketingWallet` is defensive programming: the new external call in that function is bounded by the OpenZeppelin reentrancy guard, which is shared across all `nonReentrant`-tagged functions in this contract.
- `confirmMarketingWallet` preserves checks-effects-interactions: the marketing wallet rotation state is finalized (lines 299-302) before the auto-delivery attempt (line 307), and `pendingMarketingETH` is zeroed before the send to prevent double-spend through reentry.
- Send-failure handling in `confirmMarketingWallet` is graceful: the function does not revert on delivery failure, it restores `pendingMarketingETH` and leaves the rotation itself committed. This is the correct separation of concerns: a failed send should not block a necessary wallet rotation.
- The new `maxSwapThreshold` immutable is declared public, so external callers can read the upper bound directly without calling `setSwapThreshold` with a probe value.
- No new external-call surface was introduced by the refactor. The contract's call graph remains small, with all interactions routed through OpenZeppelin v5 primitives or the trusted PancakeSwap V2 router interface.

Out of Scope and Assumptions

- OpenZeppelin v5 base contracts (ERC20, Ownable, ReentrancyGuard) are not re-audited and are assumed canonical.
- The `MoonsaleTokenFactory` that deploys this contract remains out of scope.
- The deployed router is assumed to be the canonical PancakeSwap V2 router on BNB Smart Chain at `0x10ED43C718714eb63d5aA57B78B54704E256024E` or a functionally equivalent trusted fork. The refund-accounting math in `_addLiquidity` relies on canonical router behaviour.
- The marketing wallet is assumed to accept plain ETH transfers via a non-reverting `receive()`. Under the new `confirmMarketingWallet` auto-delivery, a wallet with reverting `receive` will leave `pendingMarketingETH` set but with rotation already applied, which is the documented and accepted behaviour.
- Deployment is assumed to target a Shanghai-enabled EVM.
- No off-chain components are in scope.

Summary and Final Position

The R2 revision of MoonsaleLiquidityToken closes every actionable finding from the R1 re-audit. Three of the five R1 items are Fixed with code-level changes that match the prior recommendations exactly; the remaining two are formally Acknowledged as accepted design and deployment trade-offs. No new findings were introduced by the refactor. The contract's call graph remains minimal, all ETH-handling paths now account for pending-balance earmarking correctly, and the new confirmMarketingWallet auto-delivery closes the grieving path identified in R1 without introducing reentrancy or state-corruption risk.

Engagement Progression

The contract has undergone three rounds of review: the original audit (MSL-001, score 58/100) identified 16 findings including 3 High severity issues across the auto-liquify path. The R1 re-audit (MSL-003, score 87/100) verified the resolution of all 16 prior findings and surfaced 5 new and residual items. This R2 re-audit (MSL-005, score 94/100) confirms the resolution of 3 of those 5 R1 items and records the remaining 2 as accepted trade-offs, with no new findings. The contract is production-ready.

SECURITY SCORE

58 → 87 → 94 / 100

Disclaimer

This report is a point-in-time second re-audit of the source code revision provided to ICOGemHunters following the remediation of audit MSL-003. Findings reflect the state of the code at the commit or version indicated on the cover page. Any modification made after that point, whether by the client or a third party, invalidates the specific conclusions drawn herein.

The assessment is advisory. It does not constitute a warranty, guarantee, or insurance policy against exploits, operational failures, or economic losses. Smart contract security cannot be proven exhaustively; the absence of a finding is not a proof of absence of vulnerability. ICOGemHunters applied professional diligence and the methodology described in this document, no more and no less.

This report is not financial, legal, tax, or investment advice. Nothing in this document should be interpreted as an endorsement of the token, project, team, or any associated economic activity. Decisions to acquire, hold, transact in, or interact with MoonsaleLiquidityToken remain the sole responsibility of the user.

ICOGemHunters accepts no liability for losses, damages, or consequences arising from the client's decision not to implement the recommendations contained in this report, or from reliance on this report by any third party. The report is prepared for the named client and may not be reproduced in part without preserving this disclaimer in full.

The two Acknowledged items in this report reflect explicit design and deployment-time trade-offs communicated by the client. The client's acceptance of these trade-offs does not transfer liability to ICOGemHunters; users and integrators should review the Acknowledged section of this report to understand the residual risk surface of MoonsaleLiquidityToken.

For questions, clarifications, or a further re-assessment after additional remediation, contact ICOGemHunters through the channels published at the website listed on the cover page.

Both deployable tokens in the Moonsale engagement (MoonsaleLiquidityToken at 94/100 and MoonsaleToken at 93/100) are now cleared. The MoonsaleTokenFactory that deploys both remains the only unreviewed component and should be submitted for a separate audit to close the loop on the full deployment pipeline.